

# Network Device Compliance Report

Generated 2026-09-26 16:36

|                      |                              |
|----------------------|------------------------------|
| Device Name          | cisco_sample.cfg             |
| Detected Vendor      | Cisco                        |
| Framework            | CIS                          |
| Overall Compliance   | 35.7% (5/14 controls passed) |
| Failures by Severity | High: 5   Medium: 4   Low: 0 |

## Compliance Findings

|        |                 |      |      |
|--------|-----------------|------|------|
| CIS-01 | Telnet Disabled | High | FAIL |
|--------|-----------------|------|------|

**Description:** Telnet transmits credentials and session data in cleartext.  
**Evidence:** transport input telnet ssh  
**Why it matters:** Telnet transmits credentials and session data in cleartext. Anyone on the network path can capture an admin password with a passive sniffer.  
**Attack path:** Telnet service exposed on management interface -> Attacker sniffs management VLAN traffic -> Admin credentials captured in cleartext -> Attacker authenticates as administrator -> Full device configuration control obtained  
**Remediation:**  
line vty 0 4  
transport input ssh

|        |                        |      |      |
|--------|------------------------|------|------|
| CIS-02 | SSH Version 2 Enforced | High | FAIL |
|--------|------------------------|------|------|

**Description:** SSHv1 has known cryptographic weaknesses; only SSHv2 should be permitted.  
**Evidence:** ip ssh version 1  
**Why it matters:** SSHv1 has known cryptographic weaknesses. Only SSHv2 should be permitted.  
**Attack path:** SSHv1 supported on management interface -> Attacker performs protocol downgrade or MITM -> Session keys compromised -> Encrypted admin session decrypted -> Unauthorized administrative access  
**Remediation:**  
ip ssh version 2

|        |                          |        |      |
|--------|--------------------------|--------|------|
| CIS-03 | HTTP Management Disabled | Medium | PASS |
|--------|--------------------------|--------|------|

**Description:** Unencrypted HTTP management exposes credentials and session data.  
**Evidence:** no ip http server

|        |                          |        |      |
|--------|--------------------------|--------|------|
| CIS-04 | HTTPS Management Enabled | Medium | FAIL |
|--------|--------------------------|--------|------|

**Description:** Encrypted management access should be available as the secure alternative to HTTP.  
**Evidence:** Not found in configuration (unable to verify)  
**Why it matters:** Without HTTPS, administrators have no secure alternative to HTTP.  
**Attack path:** No encrypted web management -> Admins fall back to HTTP or Telnet -> Credentials exposed -> Device compromise  
**Remediation:**  
ip http secure-server

|        |                             |      |      |
|--------|-----------------------------|------|------|
| CIS-05 | Password Encryption Enabled | High | PASS |
|--------|-----------------------------|------|------|

**Description:** Locally stored passwords must be encrypted, not stored in plaintext.  
**Evidence:** service password-encryption

|        |                              |        |      |
|--------|------------------------------|--------|------|
| CIS-06 | Minimum Password Length >= 8 | Medium | FAIL |
|--------|------------------------------|--------|------|

**Description:** Weak minimum password length increases brute-force risk.  
**Evidence:** Not found in configuration (unable to verify)  
**Why it matters:** Short passwords are vulnerable to brute-force and dictionary attacks.  
**Attack path:** Weak password policy -> Remote brute-force attempt -> Account compromised -> Device configuration manipulated  
**Remediation:**  
security passwords min-length 8

|        |                         |     |      |
|--------|-------------------------|-----|------|
| CIS-07 | Login Banner Configured | Low | PASS |
|--------|-------------------------|-----|------|

**Description:** A legal/warning banner should be presented before authentication.

**Evidence:** banner motd ^C Authorized access only. Unauthorized use is prohibited. ^C

|        |                                |        |      |
|--------|--------------------------------|--------|------|
| CIS-08 | Session Idle Timeout <= 10 min | Medium | FAIL |
|--------|--------------------------------|--------|------|

**Description:** Idle admin sessions should time out to reduce hijack risk.

**Evidence:** exec-timeout 30 0

**Why it matters:** Idle sessions left open can be hijacked by someone with brief access to an unattended terminal.

**Attack path:** Admin leaves session unattended -> Session remains active -> Attacker uses live session -> Configuration changes made as admin

**Remediation:**

line vty 0 4  
exec-timeout 10 0

|        |                             |      |      |
|--------|-----------------------------|------|------|
| CIS-09 | Centralized Logging Enabled | High | FAIL |
|--------|-----------------------------|------|------|

**Description:** Administrative access and events must be logged for audit/forensics.

**Evidence:** Not found in configuration (unable to verify)

**Why it matters:** Without centralized logging, administrative actions and security events are invisible.

**Attack path:** No syslog destination configured -> Attacker actions leave no external trace -> Local logs cleared by attacker -> Incident response impossible

**Remediation:**

logging host  
logging trap informational

|        |                |        |      |
|--------|----------------|--------|------|
| CIS-10 | NTP Configured | Medium | PASS |
|--------|----------------|--------|------|

**Description:** Accurate time sync is required for reliable log correlation.

**Evidence:** ntp server 10.0.0.1

|        |                                             |        |      |
|--------|---------------------------------------------|--------|------|
| CIS-11 | Centralized Authentication (AAA) Configured | Medium | PASS |
|--------|---------------------------------------------|--------|------|

**Description:** Authentication should be centralized (AAA/RADIUS/TACACS+), not local-only.

**Evidence:** aaa new-model

|        |                                      |      |      |
|--------|--------------------------------------|------|------|
| CIS-12 | Management Access Restricted via ACL | High | FAIL |
|--------|--------------------------------------|------|------|

**Description:** Administrative interfaces must be restricted to trusted source addresses.

**Evidence:** Not found in configuration (unable to verify)

**Why it matters:** Management interfaces open to any source address are reachable from anywhere on the network.

**Attack path:** No ACL restricting management sources -> Attacker reaches management port -> Credential attack / exploit -> Device compromised from inside

**Remediation:**

access-list 10 permit  
line vty 0 4  
access-class 10 in

|        |                                        |      |      |
|--------|----------------------------------------|------|------|
| CIS-13 | No Default/Weak SNMP Community Strings | High | FAIL |
|--------|----------------------------------------|------|------|

**Description:** Default community strings (public/private) allow unauthorized SNMP access.

**Evidence:** snmp-server community public RO

**Why it matters:** Default SNMP community strings ('public'/'private') are known to every attacker.

**Attack path:** Default SNMP community in use -> Attacker scans with default strings -> Full device inventory disclosed -> Targeted exploitation

**Remediation:**

no snmp-server community public  
snmp-server community RO

|        |                                   |        |      |
|--------|-----------------------------------|--------|------|
| CIS-14 | Account Lockout Policy Configured | Medium | FAIL |
|--------|-----------------------------------|--------|------|

**Description:** Repeated failed logins should trigger a lockout to slow brute-force attempts.

**Evidence:** Not found in configuration (unable to verify)

**Why it matters:** Without lockout, an attacker can try unlimited passwords without triggering a defensive response.

**Attack path:** No lockout policy -> Unlimited login attempts -> Brute-force succeeds -> Admin account compromised

**Remediation:**

login block-for 120 attempts 3 within 60